

Programátorská Dokumentace – Chat app

Nástroje a Technologie

- **PHP:** Backendový jazyk, sloužící k obsluze API, správě session, databázovému přístupu (PDO) a logice aplikace.
- **MySQL:** Relační databáze pro ukládání dat o uživatelích, chatovacích místnostech a zprávách.
- **HTML:** Tvorba struktury webových stránek (index.html, šablony zobrazení).
- **CSS:** Stylování webových stránek (soubor css/styles.css a další styly specifické pro různé části aplikace).
- **JavaScript:** Klientský kód pro správu routingu, dynamické načítání obsahu a interakci s API (modulární struktura v adresáři js/).
- **PHPDocumentor:** Automatické generování PHP dokumentace (dokumentace tříd, metod a komentářů ve zdrojovém kódu).

Struktura Projektu



└─ views // Pohledy pro různé stránky (chatroomView.js, errorView.js, homeView.js, loginView.js, notFoundView.js, profileView.js, registerView.js, usersView.js)

Funkce a Logika

Registrace a Přihlášení

- **Registrace (UserController::register)**
 - Ověřuje vstupní data z formuláře (uživatelské jméno, e-mail, heslo, potvrzení hesla, profilový obrázek).
 - Validace: uživatelské jméno (3–20 znaků, povolené jsou pouze písmena, čísla a podtržítka), validita e-mailové adresy, složitost hesla.
 - Obrázky jsou validovány a zpracovány pomocí ImageUploadService.
 - Hesla jsou hashována pomocí password_hash před uložením do databáze.
 - Po úspěšné registraci je uživatelský záznam vytvořen pomocí UserModel::createUser.
- **Přihlášení (UserController::login)**
 - Přijímá JSON vstup s uživatelským jménem nebo e-mailem a heslem.
 - Na základě vstupu vyhledává uživatele (getUserByUsernameValidation nebo getUserByEmailValidation).
 - Ověřuje heslo pomocí password_verify a po úspěšném ověření nastaví session proměnné (username, role).
 - Při přihlášení se session resetuje (session_destroy() a session_start()).
- **Odhlášení (UserController::logout)**
 - Vymaže všechny session proměnné, zničí session a následně vrátí JSON odpověď s potvrzením odhlášení.

Chatovací Funkce

- **Správa Chatovacích Místností (ChatController)**
 - **Přidání chatovací místnosti (addChatroom):** Ověřuje JSON vstup obsahující název místnosti, kontroluje existenci a platnost názvu.
 - **Načítání chatovacích místností (getChatrooms):** Umožňuje stránkování (offset, limit) a filtrované hledání podle zadaného řetězce.
 - **Získání detailů místnosti (chatroomByName):** Vrací informace o existenci místnosti.
- **Zprávy**
 - **Odeslání zprávy (sendMessage):**
 - Zpráva je odeslána buď textově nebo s připojeným obrázkem.
 - Pokud je obrázek přiložen, je zpracován pomocí ImageUploadService a uložen do odpovídající složky (profilové nebo zprávové obrázky).
 - Zpráva se poté uloží pomocí metody ChatModel::addMessage.
 - **Načítání zpráv (getMessagesForChatroom a getLatestMessages):**

- Metody umožňují načíst zprávy s možností stránkování a také následné načítání nových zpráv od posledního časového razítka.
- Zprávy jsou před odesláním klientovi převedeny do přátelského formátu pomocí metody `dateConversion`.

Administrace Uživatelů

- **Získání všech uživatelů (`AdminController::getAllUsers`)**
 - Kontroluje, zda má přihlášený uživatel roli admin nebo owner.
 - Načítá seznam uživatelů s možností stránkování (`offset/limit`) a vrací celkový počet záznamů.
- **Změna uživatelské role (`AdminController::updateUserRole`)**
 - Přijímá JSON vstup s `username` a `role`.
 - Validuje délku jména, ověřuje oprávnění aktuálního uživatele a aktualizuje roli uživatele pomocí `UserModel::updateUserRole`.
 - Umožňuje pouze správné přechody – například administrátor nemůže přidělit roli owner.

Zobrazování Profilů a Správa Zpráv

- **Zobrazení profilu (`UserController::userByName` a `ProfileController::getUserMessages`)**
 - Umožňuje načíst veřejné informace o uživateli a zobrazit jeho profilovou stránku.
 - Přihlášení uživatelé mají možnost vidět a editovat své vlastní zprávy.
- **Úprava zprávy (`ProfileController::editMessage`)**
 - Umožňuje uživateli upravit vlastní zprávu pomocí JSON vstupu obsahujícího `messageId` a nový text zprávy.
 - Editace je povolena pouze, pokud zpráva skutečně náleží přihlášenému uživateli.

Zpracování Obrázků

- **ImageUploadService**
 - Obsluhuje nahrávání obrázků z formulářů, kontrolu velikosti a typu souboru.
 - Obrázky jsou vždy převedeny do formátu WebP.
 - Při nahrávání profilových fotografií je obrázek škálován na fixních 64×64 pixelů, zatímco u zpráv se dodržuje maximální rozměr 400px při zachování poměru stran.

Datové Struktury

Tabulka users

Každý uživatel má následující klíče:

- **username:** Unikátní uživatelské jméno.

- **email:** Uživatelská e-mailová adresa.
- **password:** Heslo hashované pomocí PHP funkce password_hash.
- **role:** Role uživatele (např. user, admin, owner).
- **path_topfp:** Cesta k profilové fotce uživatele.

Tabulka chatrooms

Datová struktura obsahuje minimálně:

- **id:** Unikátní identifikátor místnosti.
- **name:** Název chatovací místnosti.

Tabulka chatmessages

Obsahuje informace o každé zprávě:

- **id:** Unikátní identifikátor zprávy.
- **userId:** ID uživatele, který zprávu odeslal (může být NULL pro anonymní zprávy).
- **chatRoomId:** ID chatovací místnosti, ve které byla zpráva odeslána.
- **message:** Text zprávy.
- **timestamp:** Datum a čas odeslání zprávy.
- **path_to_image:** Cesta k obrázku, pokud byl součástí zprávy.

Bezpečnostní Opatření

1. Ochrana proti XSS:

- Řešená pomocí použití .textContent a .innerText v js. Řešené je to na stránce uživatele z důvodu zobrazování htmlspecialchars aby byly pro uživatele vidět v originální podobě.

2. Ověřování Přístupových Práv:

- Metody kontrolují, zda má uživatel odpovídající roli (např. AdminController vyžaduje role admin nebo owner).

3. Validace Dat:

- Vstupy z formulářů i JSON požadavků jsou validovány na úrovni kontrolérů (ověření délky, povolených znaků, formátu e-mailu apod.).

4. Hashování Hesel:

- Hesla jsou před uložením bezpečně hashována pomocí algoritmu PASSWORD_DEFAULT a při přihlášení ověřována funkcí password_verify.

5. Bezpečné Nahrávání Souborů:

- Obrázky jsou validovány podle MIME typu a maximální velikosti (definované v konstantě MAX_IMAGE_SIZE v config/generalConfig.php).
- Nahrané soubory se ukládají do specifických adresářů, přičemž zachovávají veřejnou cestu využívanou pro zobrazení.